

SENTINEL

MANUAL MAESTRO DE CONFIGURACIÓN Y HARDENING PERIMETRAL
FIREWALL pfSense CE 2.7.2 & SUB-SISTEMA pfctl / SURICATA IPS

PROYECTO:	KRONOS SENTINEL (APT122 - Portafolio de Título)
AUTOR:	Bruno Urrea Ortiz (Futuro Ing. en Conectividad y Redes)
INSTITUCIÓN:	Duoc UC — Sede San Joaquín
MENTORÍA ACADÉMICA:	Prof. Mauricio Carrera
SISTEMA OPERATIVO:	FreeBSD 14.0-CURRENT / pfSense CE 2.7.2 (amd64)
ARQUITECTURA:	Inline Netmap IPS + HAProxy SSL + pfBlockerNG + Gemini Live
CLASIFICACIÓN:	SEC-OPS VERIFIED & FIELD READY

PARTE 1: CONFIGURACIÓN POR INTERFAZ GRÁFICA (WebGUI)

MÓDULO 1: SETUP BASE, ASIGNACIÓN DE INTERFACES Y VLANs (802.1Q)

La arquitectura de red de KRONOS SENTINEL se estructura mediante troncales 802.1Q sobre el adaptador vtnet1 (o em1), aislando rigurosamente las zonas corporativas, servidores DMZ y telefonía VoIP:

VLAN Tag	Interfaz	Subred IPv4	Gateway pfSense	Propósito Táctico
VLAN 10	vtnet1.10	192.168.10.0/24	192.168.10.1	Estaciones de trabajo SOC y clientes.
VLAN 20	vtnet1.20	192.168.20.0/24	192.168.20.1	DMZ (Servidor Web DVWA expuesto).
VLAN 30	vtnet1.30	192.168.30.0/24	192.168.30.1	VoIP Asterisk PBX y Agente de Voz IA.
VLAN 99	vtnet1.99	192.168.99.0/24	192.168.99.1	Gestión Out-of-Band (SSH / WebGUI).

Procedimiento WebGUI:

- Navegar a **Interfaces > Assignments > VLANs** y pulsar + *Add* para registrar los tags 10, 20, 30 y 99.
- En **Interfaces > Assignments**, asociar cada interfaz virtual a un puerto lógico (OPT1 a OPT4).
- Habilitar el servidor DHCP en **Services > DHCP Server** para VLAN 10 (Rango 192.168.10.100 - 192.168.10.200) y fijar reservas estáticas para DVWA (192.168.20.50) y Asterisk (192.168.30.50).

MÓDULO 2: DESPLIEGUE DE SURICATA EN MODO INLINE IPS (NETMAP ENGINE)

Suricata 7.x opera en modo **Inline IPS** mediante el driver netmap(4) en FreeBSD, permitiendo descartar paquetes maliciosos en el anillo del hardware de red antes de que alcancen el stack IP del kernel:

Parámetros Críticos en Services > Suricata > WAN Settings:

- IPS Mode:** Inline IPS Mode (Sub-sistema Netmap activo).
- Block Offenders:** Both (Bloqueo en ambas direcciones).
- Kill States:** Enabled (Purga inmediata de estados TCP/UDP activos).
- EVE JSON Output:** Habilitar salida estructurada a /var/log/suricata/eve.json marcando *ALERTS, HTTP, TLS, DROP*.
- SID Mgmt:** Habilitar dropsid.conf para forzar acción DROP en reglas de inyección SQL (*emerging-sqli.rules*).

Advertencia de Hardening: En **System > Advanced > Networking** es mandatorio desmarcar *Hardware Checksum Offloading, TSO* y *LRO*. Netmap requiere calcular los checksums directamente para evitar caídas de interfaz.

MÓDULO 3: INTELIGENCIA GeoIP MaxMind & THREAT FEEDS (pfBlockerNG-devel)

pfBlockerNG-devel filtra el tráfico hostil conocido en Capa 3/4 mediante reglas flotantes antes de que impacte a Suricata o HAProxy:

Feed / Fuente	Tipo / URL	Acción	Frecuencia
MaxMind GeoLite2	Top Spammers / Países de Alto Riesgo	Deny Inbound	Semanal
FireHOL Level 1	firehol_level1.netset (C2/Botnets)	Deny Inbound	Cada 6 Horas
Spamhaus DROP	drop.txt / edrop.txt (BGP Hijacks)	Deny Both	Diaria
ET Compromised	compromised-ips.txt (Web Exploiters)	Deny Inbound	Cada 12 Horas

MÓDULO 4: PROXY INVERSO HAProxy & SEGURIDAD DMZ

HAProxy ejecuta terminación SSL/TLS y rate-limiting avanzado contra escáneres y ataques de denegación de servicio:

1. **Backend (bk_dwva_dmz):** Servidor 192.168.20.50:80 con health check activo HTTP y option forwardfor.
2. **Frontend (fe_wan_https):** Binds en puerto 80 (redirige 301 a HTTPS) y puerto 443 con certificado SSL.
3. **Stick Tables en Memoria:**
 - Control de conexiones TCP: rechazo si conn_cur > 20 o conn_rate(3s) > 30.
 - Control de peticiones HTTP: respuesta 429 si http_req_rate(10s) > 80.
 - Detección de Fuzzers: bloqueo si errores 4xx http_err_rate(10s) > 25.
 - Sanitización de Cabeceras: inyección estricta de X-Forwarded-For y X-Real-IP para evitar IP spoofing.

MÓDULO 5: MATRIZ DE REGLAS ZERO TRUST (WAN, DMZ, VOIP)

Interfaz	Acción	Origen	Destino	Puerto / Protocolo	Descripción
WAN	PASS	Cualquiera	WAN Address	80, 443 (TCP)	Ingreso Web a HAProxy.
DMZ	BLOCK	DMZ net	LAN net / MGMT	Cualquiera	Aislamiento total de LAN.
DMZ	BLOCK	DMZ net	pfSense IP	80, 443, 22 (TCP)	Hardening Firewall GUI.
VoIP	PASS	VoIP net	192.168.30.50	5060 (UDP/TCP)	Señalización SIP PJSIP.
VoIP	PASS	VoIP net	192.168.30.50	10000:10100 (UDP)	Canales de audio RTP.

PARTE 2: CONFIGURACIÓN AVANZADA MEDIANTE CLI / SHELL DE FREEBSD

2.1 Manipulación de la Tabla de Kernel snort2c con pfctl

El sub-sistema pfctl interactúa a nivel atómico con el kernel de FreeBSD:

```
# 1. Listar todas las direcciones IP bloqueadas en la tabla snort2c: pfctl -t snort2c -T show # 2. Test
atómico en kernel (Retorna 0 si existe, 1 si no existe): pfctl -t snort2c -T test 185.220.101.5 # 3.
Insertar dinámicamente una IP atacante: pfctl -t snort2c -T add 185.220.101.5 # 4. Purgar estados de
conexión activos bidireccionalmente (Kill States): pfctl -k 185.220.101.5 pfctl -k 0.0.0.0/0 -k
185.220.101.5 # 5. Estadísticas de paquetes descartados en memoria por tabla: pfctl -vvsTables | grep -A
8 snort2c
```

2.2 Sintonización de Alto Rendimiento para Netmap y Tablas pf

```
# Aumentar límite máximo de entradas en tablas pf a 4 Millones: sysctl net.pf.request_maxcount=4000000 #
Optimizar ring buffers del subsystem netmap(4): sysctl dev.netmap.ring_size=4096 sysctl
dev.netmap.buf_size=2048
```

2.3 Servicio Init Autónomo en FreeBSD (/usr/local/etc/rc.d/kronos_sentinel.sh)

```
#!/bin/sh # PROVIDE: kronos_sentinel # REQUIRE: NETWORKING suricata . /etc/rc.subr
name="kronos_sentinel" rcvar="kronos_sentinel_enable" command="/usr/local/bin/python3"
command_args="/usr/local/share/kronos/log_correlator.py > /var/log/kronos.log 2>&1 &" load_rc_config
$name : ${kronos_sentinel_enable:=YES} run_rc_command "$1"
```